**SIMATS ENGINEERING**

**ASSESSMENT TOOL 1**

**COURSE NAME: Ethical Hacking** **COURSE CODE: ITA14**

**COURSE OUTCOME COVERED**

**CO2:** Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

*Assessment Tool Weightage: 30%*

**Duration: 90 min** **Total Marks: 50**

**Report Analysis**

***Code of Conduct:***

*I **D K SUMALATHA(192424023)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

*I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:***

***D K Sumalatha***

**Question 1: Analysis of Nmap Network Scan Report (20 Marks)**

**1. Introduction**

Nmap (Network Mapper) is a network scanning tool used by security analysts and ethical hackers to identify open ports, running services, service versions, and operating systems on a target system. It helps identify potential vulnerabilities and assess the security of a network.

In this scenario, the security analyst scanned the target system **192.168.1.10** and identified the following open ports:

| Port Number | Service | Purpose |
|---|---|---|
| 22 | SSH | Secure remote login and administration |
| 80 | HTTP | Hosting websites and web applications |
| 3306 | MySQL | Database management and storage |

The report also provides operating system and service version information. This information can help administrators identify outdated software and potential security weaknesses.

**2. Analysis of Identified Services and Security Risks**

**A. SSH – Port 22**

**Purpose:** SSH (Secure Shell) provides encrypted remote access to a computer or server.

**Security risks:**

1. **Brute-force attacks:** Attackers may repeatedly attempt to guess usernames and passwords.
2. **Weak authentication:** Easily guessed or reused passwords can allow unauthorized access.
3. **Outdated software:** Vulnerable SSH versions may contain security flaws that attackers can exploit.
4. **Unauthorized remote access:** If an attacker obtains valid credentials, they may access the server and execute commands according to the privileges of the compromised account.

**Possible exploitation:** An attacker may identify the SSH service and its version using network scanning. If weak credentials or a known vulnerability exist, the attacker may attempt to gain unauthorized access.

**Countermeasures:**

- Use SSH keys or other strong authentication methods instead of password-only authentication where practical.
- Disable direct root login.
- Enforce strong passwords and multi-factor authentication where supported.

- Keep the SSH server and operating system updated.
- Restrict SSH access to authorized IP addresses through firewall rules or a VPN.
- Monitor login attempts and use rate limiting or tools such as Fail2ban where appropriate.

**B. HTTP – Port 80**

**Purpose:** HTTP is used to deliver website content and communicate between web browsers and web servers.

**Security risks:**

1. **Unencrypted communication:** HTTP does not encrypt traffic, so sensitive information transmitted over it may be intercepted.
2. **Web application vulnerabilities:** SQL injection, cross-site scripting (XSS), and other flaws may expose data or allow unauthorized actions if the application is vulnerable.
3. **Information disclosure:** Default pages, server banners, directory listings, or detailed error messages may reveal useful information.
4. **Outdated web server software:** Older versions may contain publicly known vulnerabilities.
5. **Session security weaknesses:** Inadequately protected sessions may be exposed to theft or misuse.

**Possible exploitation:** An attacker may inspect the website, identify the server software, and test the application for known weaknesses. If a vulnerable application is present, the attacker may attempt to access sensitive data or perform unauthorized actions.

**Countermeasures:**

- Enable HTTPS using a valid TLS certificate and redirect HTTP requests to HTTPS.
- Update the web server, frameworks, and application components regularly.
- Validate user input and use parameterized SQL queries to prevent SQL injection.
- Apply output encoding and appropriate security controls to reduce XSS risks.
- Disable unnecessary directory listings and remove default pages.
- Configure secure session cookies and appropriate HTTP security headers.
- Use a web application firewall (WAF) where appropriate.
- Perform regular vulnerability assessments and authorized penetration tests.

**C. MySQL – Port 3306**

**Purpose:** MySQL is a relational database management system used to store and retrieve application data.

**Security risks:**

1. **Unauthorized database access:** Weak passwords or excessive permissions may allow unauthorized users to access data.
2. **Exposure to the network:** If the database is accessible from untrusted networks, attackers have a larger opportunity to target it.
3. **Sensitive data leakage:** The database may contain personal information, credentials, financial records, or business data.
4. **SQL injection:** Vulnerable applications connected to the database may allow attackers to manipulate database queries.
5. **Outdated database software:** Unpatched versions may contain known vulnerabilities.
6. **Excessive privileges:** An account with unnecessary administrative permissions may increase the damage caused by a compromise.

**Possible exploitation:** An attacker may identify MySQL on port 3306 and attempt to determine its version. If the service is unnecessarily exposed, uses weak credentials, or contains an exploitable vulnerability, the attacker may attempt unauthorized database access or data theft.

**Countermeasures:**

- Do not expose MySQL directly to the public internet.
- Configure the firewall to allow database connections only from authorized application servers or administrator systems.
- Bind MySQL to an appropriate private interface or localhost when remote access is unnecessary.
- Use strong, unique database credentials.
- Apply the principle of least privilege to database accounts.
- Update MySQL to a supported, patched version.
- Use encrypted connections for remote database access.
- Enable database auditing and monitor unusual login attempts and queries.
- Maintain regular, tested backups and protect them from unauthorized access.

**3. Risks Associated with Operating System and Service Versions**

The Nmap report identifies the operating system and service versions. This information is useful for administrators but may also assist attackers during reconnaissance.

The major risks include:

- **Version identification:** Attackers can compare the detected versions with publicly documented vulnerabilities.
- **Known vulnerability exploitation:** Outdated services may be vulnerable to attacks for which patches are available.

- **Operating system weaknesses:** An unsupported operating system may no longer receive security updates.
- **Targeted attacks:** Attackers can use the information to select techniques appropriate to the detected software.

However, identifying a service version does not automatically prove that the system is vulnerable. The actual risk depends on the exact version, configuration, installed patches, network exposure, and available mitigations.

**Recommended measures:**

1. Maintain an inventory of operating systems and software versions.
2. Remove unsupported software and upgrade vulnerable components.
3. Apply security patches promptly according to risk.
4. Disable unnecessary services and close unused ports.
5. Verify findings through authorized vulnerability scanning.
6. Use intrusion detection and prevention systems where appropriate.

**4. Overall Security Assessment**

The open ports indicate that the system provides remote administration, web services, and database functionality. These services may be necessary for business operations, but each introduces potential attack surfaces.

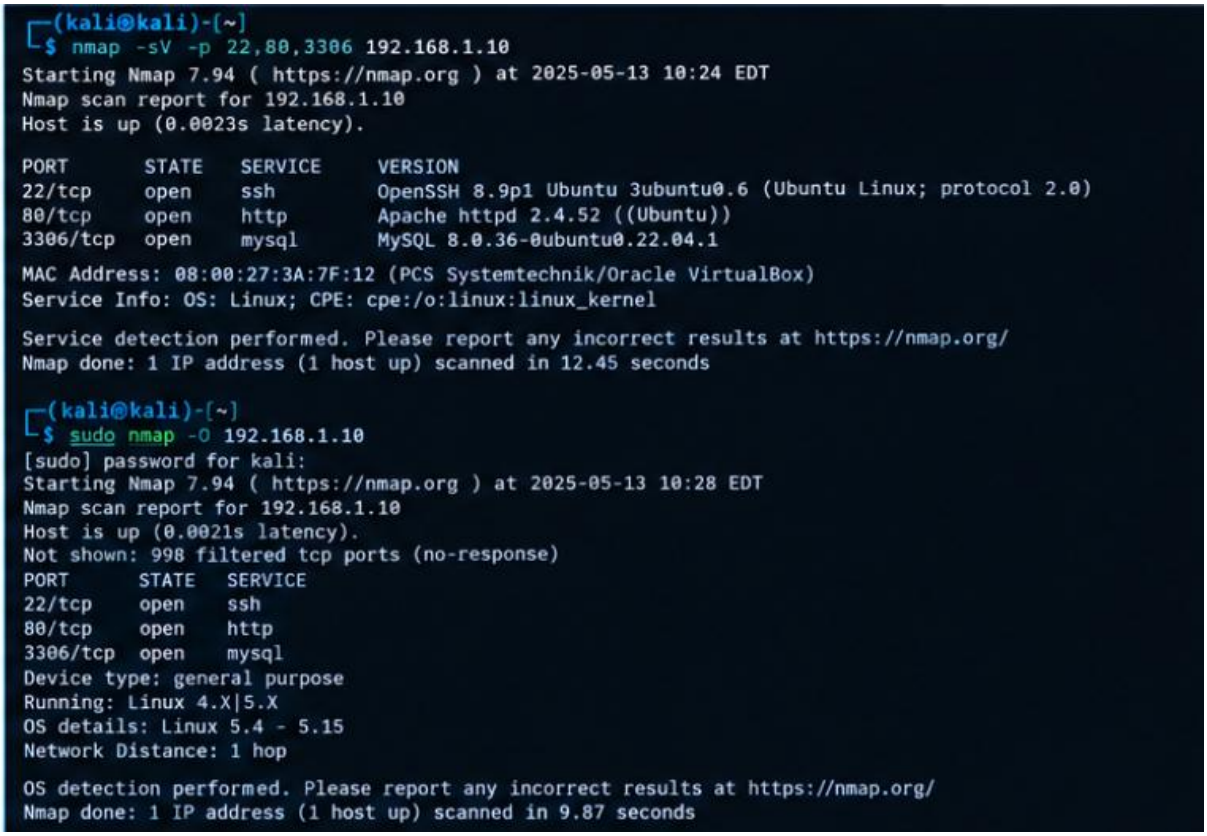
The most important concern is whether MySQL is unnecessarily accessible to other systems, whether SSH access is adequately restricted, and whether the website uses secure communication and secure application coding practices.

The organization should prioritize limiting network exposure, updating software, strengthening authentication, and monitoring suspicious activity.

**5. Conclusion**

The Nmap report helps the security analyst understand the services running on 192.168.1.10 and identify areas requiring further security assessment. SSH may be targeted through weak authentication, HTTP through insecure communication or application vulnerabilities, and MySQL through unauthorized database access or excessive exposure.

By implementing strong authentication, HTTPS, firewall restrictions, database access controls, regular patching, and continuous monitoring, the organization can reduce the likelihood and impact of cyberattacks. All scanning and testing should be performed only on systems for which authorization has been granted.




**Question 2: Analysis of GoPhish Phishing Awareness Campaign (20 Marks)**

**1. Introduction**

Phishing is a social engineering attack in which an attacker impersonates a trusted person or organization to trick users into revealing confidential information, clicking malicious links, or downloading harmful attachments.

GoPhish is an open-source phishing simulation platform that organizations can use to conduct authorized phishing awareness campaigns and evaluate employee responses.

In this scenario, ABC Technologies Pvt. Ltd. conducted a phishing awareness campaign and obtained the following results:

| **Campaign finding** | **Percentage or observation** |
|---|---|
| Employees who clicked the phishing link | 40% |
| Employees who entered login credentials | 20% |
| Employees who downloaded a malicious attachment | Several users |

These results indicate that some employees may not be sufficiently prepared to identify and respond to phishing attempts.

**2. Analysis of the Report**

**A. High Click Rate – 40%**

A click rate of 40% indicates that a substantial proportion of employees interacted with the simulated phishing link.

**Security weaknesses demonstrated:**

1. Employees may not carefully inspect links before clicking.
2. Users may trust emails that appear to come from managers, colleagues, banks, or service providers.
3. Employees may be influenced by urgent messages, attractive offers, or threats of account suspension.
4. Some users may lack sufficient knowledge of phishing indicators.

**Security implications:**

Clicking a malicious link may redirect a user to a fraudulent website, trigger a drive-by attack in a vulnerable environment, or initiate further social engineering. Clicking alone does not necessarily mean that a system has been compromised, but it represents a potential risk.

**B. Credential Submission Rate – 20%**

The report indicates that 20% of employees entered their login credentials on the simulated phishing page.

**Security weaknesses demonstrated:**

1. Employees may fail to verify the authenticity of login pages.
2. Users may not recognize suspicious URLs or lookalike domains.
3. Password reuse may increase the impact of credential theft.
4. Employees may be unaware of multi-factor authentication and account protection practices.

**Security implications:**

If real credentials are stolen, attackers may use them to attempt unauthorized access to email, internal applications, cloud services, or other systems. Reused passwords can allow a compromise in one service to affect other accounts. Stolen credentials may also support further phishing or privilege escalation attempts.

**C. Malicious Attachment Downloads**

Several employees downloaded a simulated malicious attachment.

**Security weaknesses demonstrated:**

1. Employees may open unexpected attachments without verifying the sender.
2. File extensions and suspicious attachment names may be overlooked.
3. Users may not understand the risks of enabling macros or executing unknown files.
4. Employees may ignore organizational procedures for reporting suspicious emails.

**Security implications:**

A genuinely malicious attachment may contain malware, ransomware, spyware, or a remote-access payload. Depending on the file type, software vulnerabilities, and user actions, it may lead to data theft, unauthorized access, or disruption of business operations.

Downloading a file alone does not prove that malware executed or that a device was infected. The organization should investigate any real suspicious download.

**3. Employee Awareness Programs**

ABC Technologies should implement a continuous security awareness program.

**A. Regular Phishing Awareness Training**

Conduct training sessions to teach employees how to identify suspicious emails, links, and attachments.

Training should cover:

- Unexpected requests for passwords or confidential information.
- Urgent or threatening language designed to pressure employees.
- Suspicious sender addresses and lookalike domains.
- Unusual attachments and unexpected invoices.
- Links whose displayed text does not match their destination.
- Requests to bypass established security procedures.

**B. Simulated Phishing Exercises**

Conduct authorized phishing simulations periodically using GoPhish.

The organization should:

1. Use realistic but safe simulation templates.
2. Explain the purpose of the campaign to employees through an appropriate awareness program.
3. Measure click rates, credential-submission attempts, attachment interactions, and reporting rates.
4. Provide immediate, supportive educational feedback to users who fall for a simulation.
5. Compare results across campaigns to identify improvements.

The purpose should be to strengthen security behaviour, not to shame individual employees.

**C. Practical Demonstrations**

Provide short demonstrations showing how to inspect sender addresses, preview links, report suspicious messages, and verify unusual requests through a separate trusted communication channel.

### D. Role-Based Training

Provide additional training for employees with access to sensitive data, finance teams, system administrators, and senior management because their accounts may present higher-value targets.

## 4. Email Security Controls

The organization should implement technical controls to prevent phishing emails from reaching employees and reduce the impact of successful attacks.

### A. Email Filtering

Use a secure email gateway or advanced email protection service to detect spam, spoofing, malicious links, and dangerous attachments.

### B. SPF, DKIM, and DMARC

- **SPF (Sender Policy Framework):** Identifies mail servers authorized to send email for a domain.
- **DKIM (DomainKeys Identified Mail):** Uses a digital signature to help verify that an email was authorized by the signing domain and has not been altered in transit.
- **DMARC (Domain-based Message Authentication, Reporting, and Conformance):** Defines how receiving systems should handle messages that fail relevant authentication and alignment checks, and provides reporting capabilities.

Proper configuration of these mechanisms helps reduce domain spoofing. However, they do not eliminate every form of phishing.

### C. URL and Attachment Protection

- Use URL filtering and reputation analysis to block known malicious websites.
- Scan email attachments for malware.
- Use sandboxing to examine suspicious files in an isolated environment.
- Block or restrict risky file types where business requirements permit.
- Apply appropriate protections to files downloaded from the internet.

### D. Multi-Factor Authentication (MFA)

Enable MFA for email, remote access, administrative accounts, and important business applications. Prefer phishing-resistant methods, such as FIDO2 security keys or passkeys, where supported.

MFA reduces the risk of account compromise but should be combined with other controls because some authentication methods can still be targeted by sophisticated phishing attacks.

### E. Endpoint Protection

Deploy endpoint detection and response (EDR) or suitable antivirus solutions to identify suspicious activity, detect malware, and support incident investigation.

**F. Least Privilege and Patching**

Restrict user permissions and regularly patch operating systems, browsers, email clients, and document applications. This limits the damage that may occur if a malicious file is opened.

**5. Organizational Policies**

ABC Technologies should establish and enforce the following policies:

1. **Email Usage Policy:** Define acceptable email use and procedures for handling suspicious messages.
2. **Password Policy:** Require unique passwords, encourage password managers, and prohibit password sharing.
3. **MFA Policy:** Require MFA for important accounts and privileged access.
4. **Attachment Handling Policy:** Require verification of unexpected files and prohibit unauthorized execution of suspicious attachments.
5. **Incident Reporting Policy:** Provide a simple process for reporting phishing emails and suspected compromises.
6. **Access Control Policy:** Apply least privilege and review account permissions regularly.
7. **Incident Response Policy:** Define procedures for isolating affected devices, resetting compromised credentials, revoking active sessions, and investigating security incidents.
8. **Security Awareness Policy:** Require regular training and evaluate its effectiveness.

Employees should be encouraged to report mistakes quickly without fear of unfair punishment. Early reporting helps the security team respond before a potential incident becomes more serious.

**6. Evaluation and Improvement**

The organization should use measurable indicators to assess the effectiveness of its awareness program.

| **Metric** | **Purpose** |
|---|---|
| Phishing click rate | Measures how often users interact with simulated phishing links |
| Credential-submission rate | Measures the proportion of users attempting to submit credentials to simulated phishing pages |
| Attachment interaction rate | Measures user interaction with simulated risky attachments |
| Phishing reporting rate | Measures how often employees report suspicious messages |
| Time to report | Measures how quickly employees alert the security team |

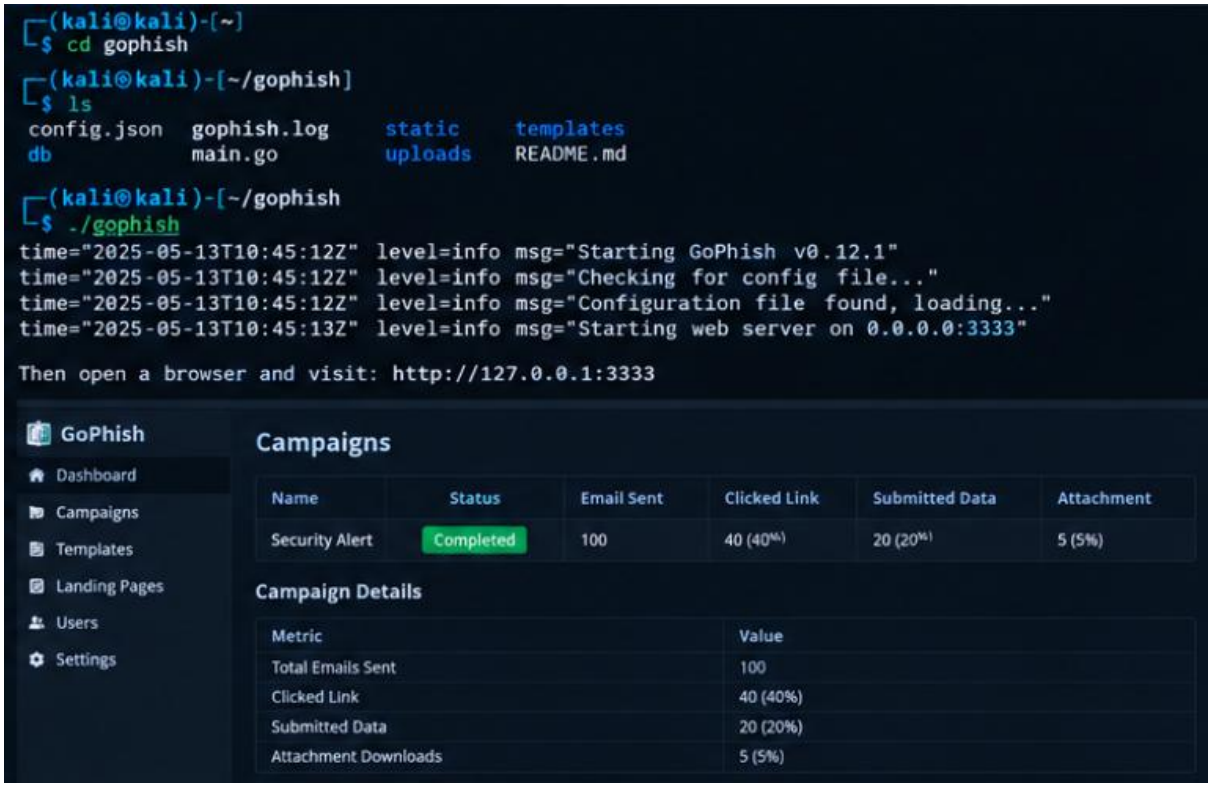
| | |
|---|---|
| Repeat failure rate | Identifies whether further training may be needed |

The organization should compare these measures across campaigns, use consistent definitions, and consider differences in campaign difficulty. A lower click rate and credential-submission rate, together with a higher reporting rate, would generally indicate improvement.

### 7. Conclusion

The GoPhish report reveals important weaknesses in employee awareness at ABC Technologies Pvt. Ltd. The 40% click rate, 20% credential-submission rate, and attachment downloads indicate that phishing remains a significant organizational risk.

The organization should combine regular awareness training, simulated phishing exercises, secure email gateways, SPF/DKIM/DMARC, MFA, endpoint protection, and clearly defined security policies. Continuous measurement and supportive feedback can improve employee behaviour and reduce the risk of successful social engineering attacks.




## Question 3: Analysis of DNS Zone Transfer (AXFR) Report (10 Marks)

### 1. Introduction

The Domain Name System (DNS) translates domain names into IP addresses and helps users access websites, email servers, and other network services.

A DNS zone transfer is a mechanism that allows DNS servers to replicate DNS records. AXFR is a DNS query type used to request a full zone transfer, commonly between primary and secondary DNS servers.

In this scenario, a DNS assessment performed using the Dig tool shows that the organization's DNS server permits an unauthorized or insufficiently restricted AXFR request. As a result, internal hostnames, mail servers, and other DNS records are exposed.

**2. Analysis of the Report**

A successful AXFR response may reveal DNS information such as:

- Internal or external hostnames.
- IP addresses associated with systems.
- Mail exchange (MX) records identifying mail servers.
- Nameserver (NS) records.
- Service-related records and subdomain names.
- Other records present in the transferred DNS zone.

The seriousness of the finding depends on whether the transferred zone contains sensitive internal information or only publicly intended records.

**3. Security Implications**

**A. Information Disclosure**

An attacker may obtain a list of systems and services without individually discovering each hostname. Internal naming conventions may reveal server roles, departments, development environments, or administrative systems.

**B. Improved Reconnaissance**

The exposed information can help attackers understand the organization's network structure and identify potentially valuable targets.

**C. Targeted Attacks**

Mail server records may help attackers identify email infrastructure for phishing, spoofing attempts, or service-targeted attacks. Hostnames suggesting administrative or development functions may attract additional investigation.

**D. Identification of Weak Systems**

If exposed hostnames reveal outdated applications, test servers, or administrative interfaces, attackers may prioritize those systems for further authorized or unauthorized probing.

**E. Increased Risk of Further Attacks**

DNS zone transfer exposure does not automatically provide access to internal systems. However, it can reduce the effort needed for reconnaissance and make subsequent attacks more targeted.

**4. How Attackers Could Exploit the Findings**

An attacker could potentially:

1. Request a DNS zone transfer from a misconfigured DNS server.
2. Collect the returned hostnames, IP addresses, and DNS records.
3. Identify interesting systems, such as mail servers, development systems, or administrative hosts.
4. Compare publicly exposed service information with known vulnerabilities.
5. Attempt phishing, service probing, or other attacks against identified targets.

These actions illustrate the potential attack path and should only be reproduced in an authorized testing environment.

## 5. Best Practices to Secure DNS Infrastructure

### A. Restrict Zone Transfers

Configure DNS servers to permit AXFR only to explicitly authorized secondary DNS servers. Deny zone transfers to all other clients.

### B. Use Transaction Signatures (TSIG)

Use TSIG or another supported secure mechanism to authenticate and protect authorized DNS zone transfers against unauthorized requests and tampering.

### C. Separate Internal and External DNS

Use split-horizon DNS or separate internal and external DNS zones so that internal hostnames and private infrastructure details are not unnecessarily exposed to external users.

### D. Minimize Information Disclosure

Remove unnecessary DNS records and avoid publishing sensitive internal naming details in externally accessible zones.

### E. Monitor DNS Activity

Log and review DNS queries, zone-transfer attempts, configuration changes, and unusual access patterns. Alert administrators when unauthorized AXFR requests occur.

### F. Regular DNS Auditing

Perform authorized DNS security assessments regularly to verify zone-transfer restrictions, review DNS records, and identify configuration errors.

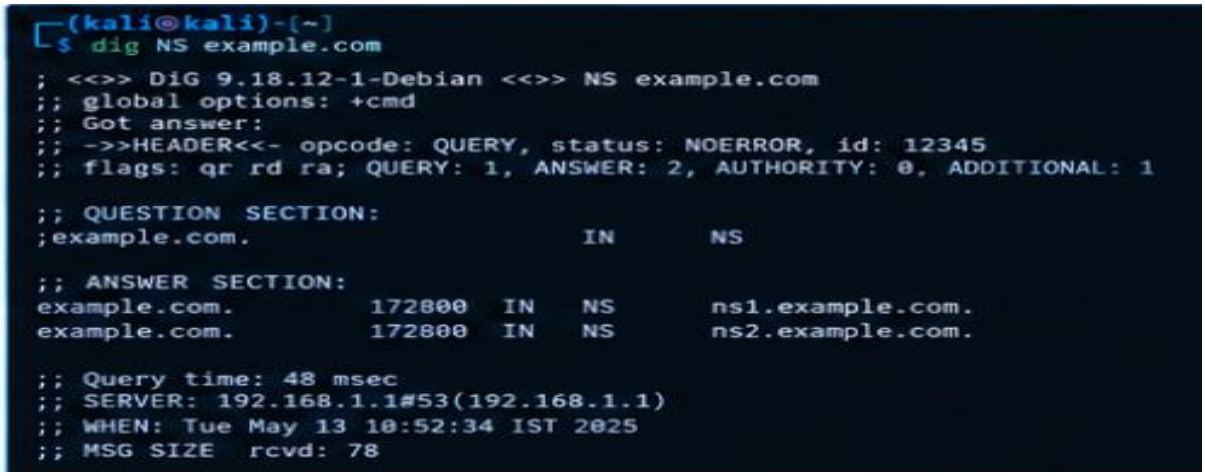
### G. Secure DNS Administration

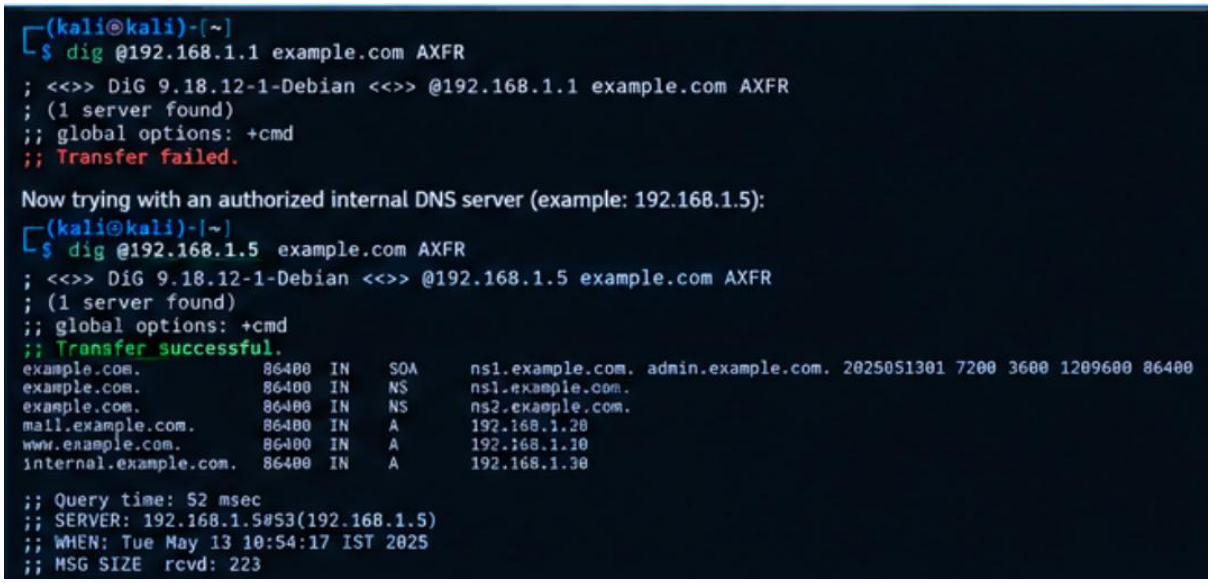
Restrict administrative access, use strong authentication, apply software updates, and maintain tested backups of DNS configuration files.

## 6. Conclusion

The DNS assessment identifies a potentially serious information-disclosure vulnerability because an unauthorized client can retrieve a complete DNS zone. Exposed hostnames, mail server details, and other records can help attackers perform reconnaissance and plan more targeted attacks.

The organization should restrict AXFR to authorized secondary DNS servers, authenticate zone transfers using TSIG where supported, separate internal and external DNS, minimize unnecessary records, and continuously monitor DNS activity. These measures reduce information leakage and strengthen the security of the organization's DNS infrastructure.



**RUBRICS FOR CALCULATION**

**Report Analysis**

| Criteria | Weightage (%) | Level 4 (Exemplary) | Level 3 (Proficient) | Level 2 (Developing) | Level 1 (Beginning) |
|---|---|---|---|---|---|
| Report Analysis and Interpretation | 25% | Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding. | Correctly interprets most findings with minor omissions or inaccuracies. | Identifies only some findings and provides limited interpretation. | Unable to interpret the report or identify key findings. |
| Identification of Security Risks and Vulnerabilities | 25% | Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification. | Identifies most risks and vulnerabilities with minor errors. | Identifies only a few risks with limited technical explanation. | Fails to identify major risks or vulnerabilities. |
| Application of Cybersecurity Concepts and Countermeasures | 30% | Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures. | Recommends suitable countermeasures with minor technical gaps. | Provides limited or partially appropriate recommendations. | Recommendations are inappropriate, incomplete, or missing. |

| | | | | | |
|---|---|---|---|---|---|
| Technical Communication and Documentation | 20% | Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout. | Response is organized and understandable with minor documentation or presentation issues. | Response lacks clarity, organization, or contains several technical inaccuracies. | Response is poorly organized, incomplete, and difficult to understand. |